

Varredura de portas e enumeração

Aula 04 • Da tradução de endereços à varredura de portas

Sistemas de Informação • Ensino noturno • 18h25–22h05

Prof. José Carlos Neto <j.neto@ufn.edu.br>

Unidade 1 – Segurança de redes locais e de longa distância

Subunidade 1.2 – Continuidade: varredura e enumeração de serviços

0	1	0	1	0	1
1	1	0	0	1	1
0	0	0	0	0	0
1	0	1	0	1	1
1	1	1	1	1	0
1	0	0	1	1	0
0	1	0	1	1	1
0	0	1	1	0	1
0	1	1	1	0	1

0 que vimos na Aula 03

Antes de seguir, um resumo rápido dos conceitos que vamos usar hoje como base.



Endereços válidos e inválidos

IP público (roteável) x IP privado (RFC 1918) – e por que a internet descarta pacotes privados.



Tabela de tradução do NAT

IP interno + porta interna $\leftrightarrow$ IP público + porta traduzida – o mecanismo que devolve cada resposta.



CGNAT e IPv6

NAT em escala do provedor, e por que IPv6 tecnicamente elimina a necessidade de NAT.



NAT: Static, Dynamic e PAT/Overload

Como um roteador reescreve endereços e portas para que hosts privados saiam para a internet.



Port Forwarding, DMZ e NAT Traversal

Como expor um serviço de propósito, e como VoIP/P2P contornam o NAT (STUN/TURN/ICE).



Ferramentas de reconhecimento

traceroute, nslookup/dig e whois – o primeiro contato com a infraestrutura de um alvo.

0 que veremos hoje

Da varredura de portas à enumeração de serviços – e como o NAT visto na Aula 03 molda tudo isso.

- 01 Como a aula vai funcionar hoje (blocos e intervalo)
- 02 Da tradução de endereços à varredura de portas
- 03 Revisão rápida: handshake TCP e fases de um teste de invasão
- 04 Varredura de portas: conceito, estados e tipos de scan
- 05 Nmap: a ferramenta padrão de mercado
- 06 Enumeração de serviços: banner grabbing e scripts NSE
- 07 NAT e varredura: o que um testador externo realmente enxerga
- 08 Aspectos legais: varredura não autorizada é crime
- 09 Atividade prática guiada e em duplas

Como a aula vai funcionar hoje

Quase 4 horas de aula – por isso vamos alternar teoria, exemplos e prática em blocos, com uma pausa no meio.

BLOCO 1 · TEORIA

Da NAT à varredura de portas: conceito, estados de porta e tipos de scan.

BLOCO 2 · FERRAMENTA

Nmap na prática: sintaxe, exemplo de saída e enumeração de serviços.

INTERVALO · 15 MIN

Uma pausa no meio da aula para descansar antes da parte prática.

BLOCO 3 · PRÁTICA

Atividade guiada e exercícios em duplas, interpretando saídas reais de varredura.

O objetivo é sair de hoje sabendo rodar e interpretar uma varredura básica – sem decorar comandos de cor.

SUBUNIDADE 1.2 • CONTINUAÇÃO

Da tradução de endereços à varredura de portas

Modalidade: Presencial • Turma noturna • 18h25 às 22h05

0 que estudaremos?

Hoje vamos aprender como um testador de invasão descobre, de fora para dentro, quais portas estão abertas em uma rede-alvo e quais serviços estão rodando nelas – e como o NAT visto na Aula 03 limita ou direciona esse reconhecimento. Faremos exercícios práticos em sala para fixar o conteúdo.

Varredura de portas

Estados de porta

Nmap

Enumeração de serviços

NAT e reconhecimento

Nota: assim como um endereço privado precisa ser traduzido pelo NAT para sair, um host atrás do NAT também precisa de uma regra explícita (port forwarding) para ser alcançado de fora – é exatamente esse limite que molda uma varredura externa.

Competências e objetivos

COMPETÊNCIAS

Reconhecer protocolos e realizar varredura e enumeração

Compreender o que são vulnerabilidades em sistemas computacionais de forma a identificar falhas em protocolos, e aplicar técnicas de varredura de portas e enumeração de serviços como parte de um teste de invasão.

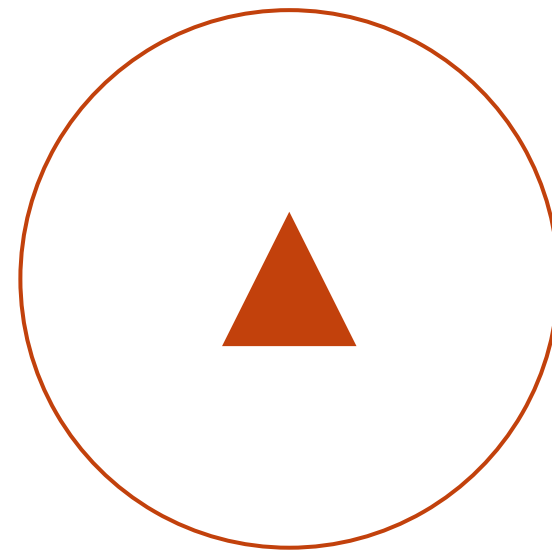
OBJETIVOS

Reconhecer os protocolos e suas aplicações na prática

Consolidar a identificação de falhas em protocolos como base para os testes de invasão, relacionando os resultados de uma varredura com o comportamento do NAT estudado na aula anterior.

Se um host está atrás do NAT,
como um
testador de fora
descobre o que existe ali?

Sobre o que refletiremos: a Aula 03 mostrou que hosts atrás do NAT não são endereçáveis diretamente de fora. Então como um testador de invasão mapeia portas e serviços de uma rede que ele não pode ver diretamente? A resposta está no que é alcançável de fora – e é isso que a varredura de portas revela.



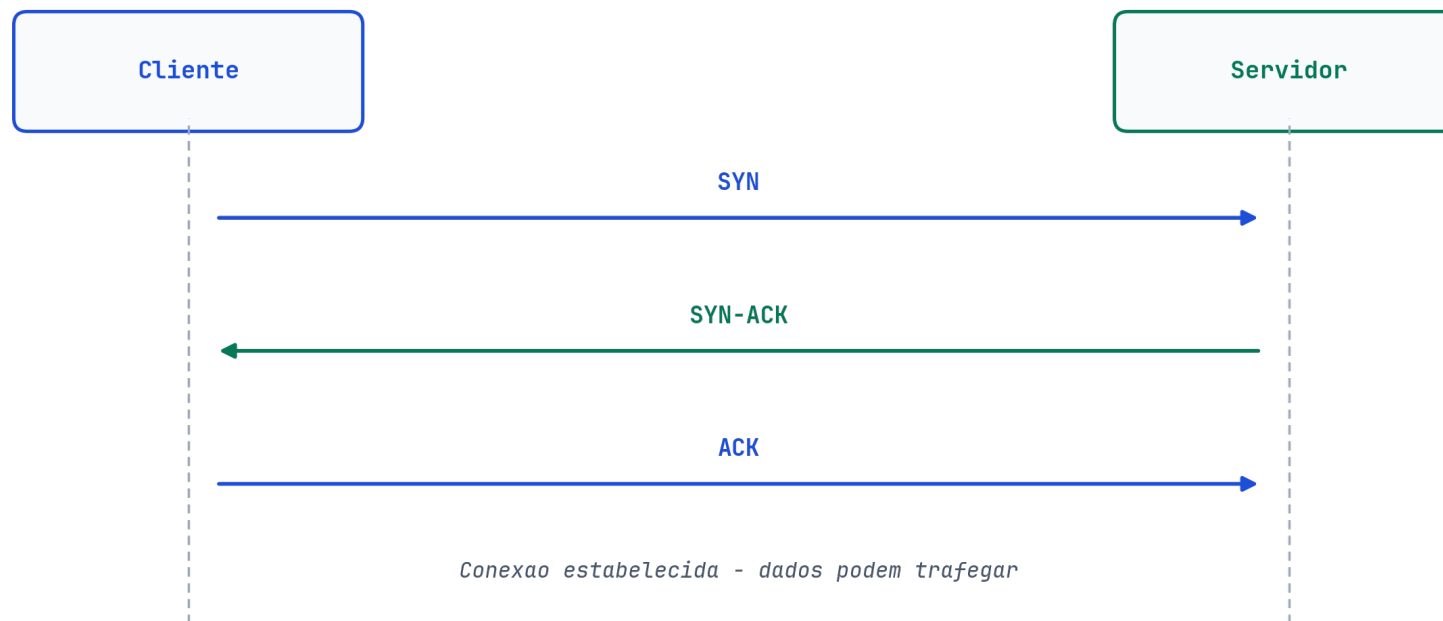
Onde a varredura entra no teste de invasão

Já vimos essas fases na Aula 02 – hoje vamos aprofundar a segunda etapa.



Revisão rápida: o handshake do TCP

Entender os tipos de scan exige lembrar como uma conexão TCP normal se estabelece.



O SYN scan interrompe esse processo de propósito logo após o SYN-ACK – veremos por quê a seguir.

0 que é varredura de portas

Port scanning é a técnica de enviar pacotes especialmente formados para um conjunto de portas de um host, e interpretar as respostas (ou a ausência delas) para descobrir quais serviços estão escutando ali.

Por que é o próximo passo

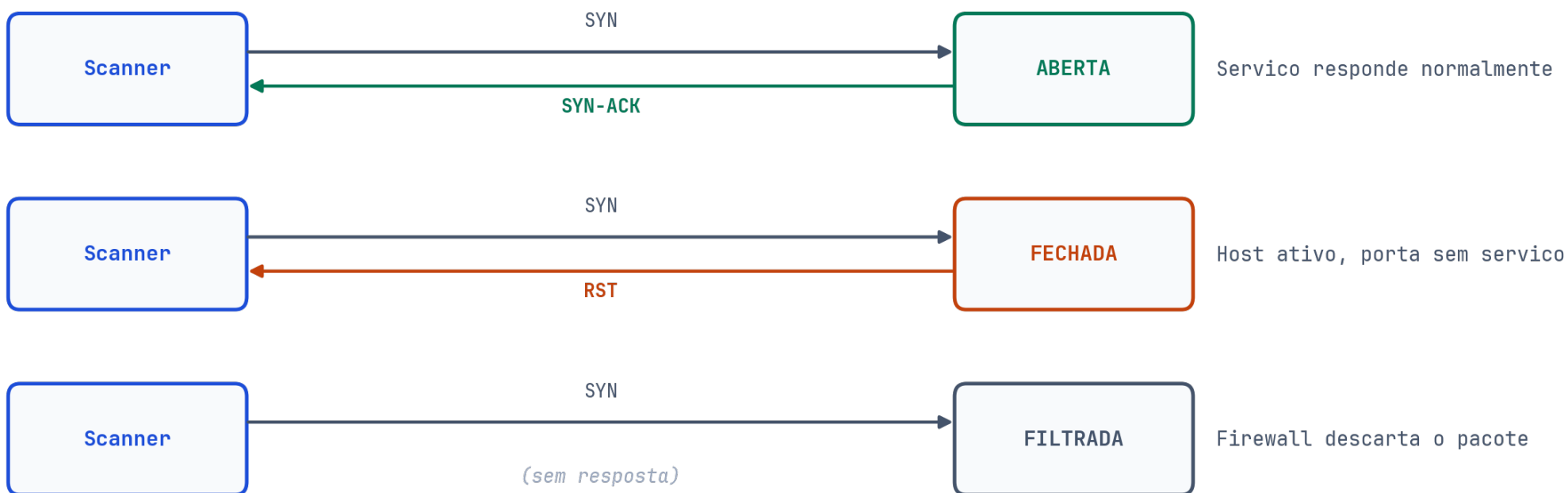
O reconhecimento passivo (whois, DNS) revela domínios e IPs – a varredura revela o que está ativo neles.

Autorizado x não autorizado

A mesma técnica usada em um pentest contratado é usada por um atacante – o que muda é a autorização.

Os três estados possíveis de uma porta

Toda ferramenta de varredura classifica cada porta testada em um destes três estados.



Tipos de scan TCP

Cada tipo interrompe o handshake em um ponto diferente – o que muda a velocidade e a descrição do scan.

Tipo	Também chamado	Como funciona	Característica
SYN scan	Half-open / stealth	Envia SYN, recebe SYN-ACK, mas nunca completa com ACK	Rápido e o mais usado – exige privilégio administrativo
Connect scan	TCP connect	Completa o handshake normalmente, como uma aplicação real	Mais lento e detectável, mas não exige privilégio especial
ACK scan	–	Envia apenas ACK, sem handshake prévio	Não detecta porta aberta – mapeia regras de firewall
FIN / NULL / XMAS	Scans stealth	Envia flags incomuns (FIN, nenhuma, ou várias) fora de contexto	Tenta passar despercebido por firewalls simples

Controlando a velocidade: timing templates

A flag `-T` define o equilíbrio entre velocidade e descrição – de 0 (paranoico) a 5 (insano).



Na prática: `-T4` é o padrão recomendado. Os extremos (`-T0/-T1`) servem para evasão deliberada; `-T5` arrisca perder respostas.

Por que a varredura UDP é mais difícil

UDP não tem handshake – e isso muda completamente a lógica da varredura.

TCP (com handshake)

A ausência de resposta ao SYN geralmente significa porta filtrada – o comportamento é previsível e rápido de interpretar.

UDP (sem handshake)

Sem resposta pode significar porta aberta OU filtrada – a única forma de confirmar é enviar um payload específico do protocolo e esperar (ou não) uma resposta de aplicação. É por isso que scans UDP são muito mais lentos.

NAT e varredura: o que muda na prática

A tabela de tradução da Aula 03 explica diretamente por que um scan externo enxerga tão pouco.

Um scan de fora para dentro (black box) atinge apenas o endereço público do roteador – as portas que aparecem “abertas” são exatamente aquelas com port forwarding ou DMZ configurados. Os demais hosts internos permanecem completamente invisíveis para essa varredura.

De fora (antes do NAT)

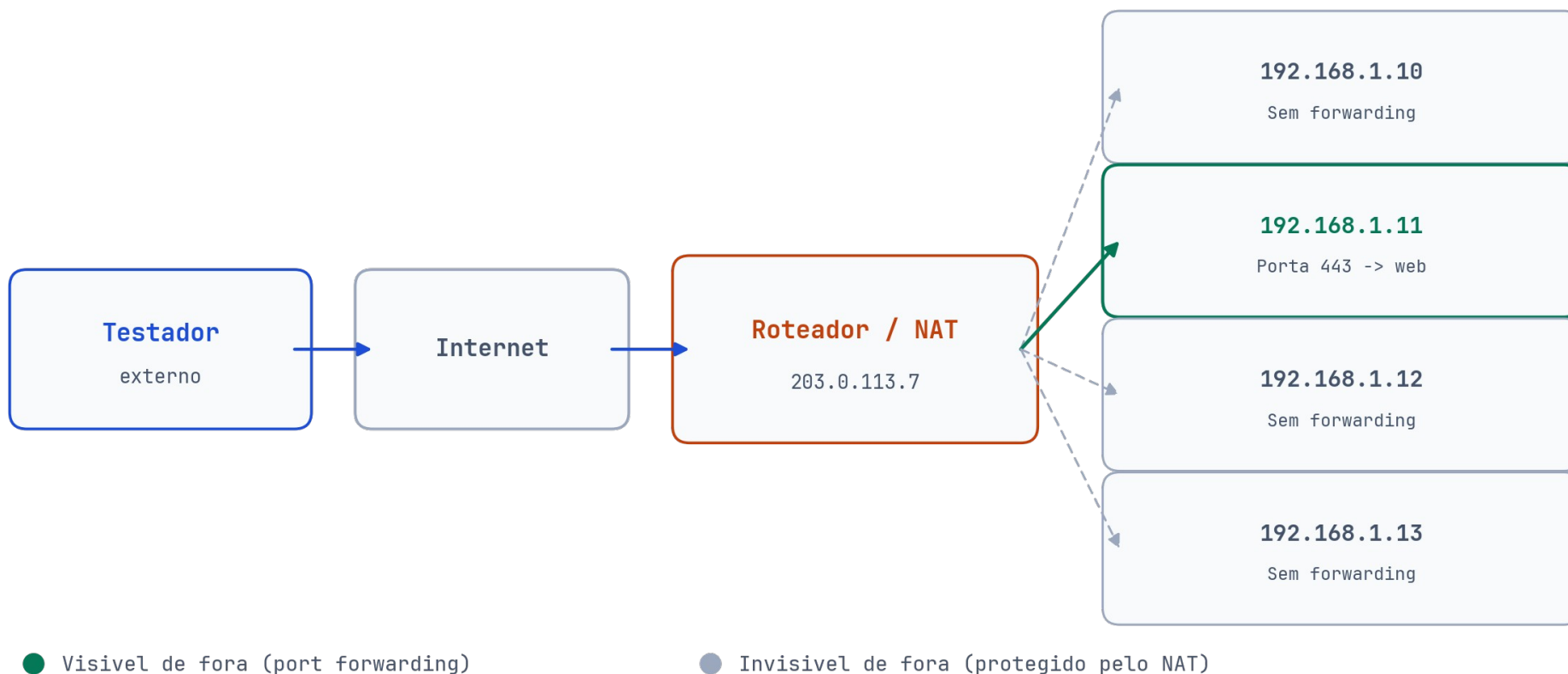
O scan só vê o IP público e as portas explicitamente encaminhadas – normalmente 2 ou 3 serviços, no máximo.

De dentro (depois de um acesso inicial)

Uma vez com acesso a um host interno, o testador enxerga a rede local como qualquer outro dispositivo dela – sem NAT no caminho.

Em diagrama: o que o testador realmente enxerga

Só a porta com port forwarding aparece – os demais hosts internos ficam fora do alcance do scan.



Nmap: a ferramenta padrão de mercado

Network Mapper – de código aberto, criada em 1997 – é a ferramenta de varredura mais usada em pentests profissionais, CTFs e certificações da área. Praticamente todo profissional de segurança de rede sabe ler um resultado de nmap.

O que ela faz

Varre portas TCP/UDP, identifica versões de serviço, detecta sistema operacional e roda scripts de enumeração – tudo em uma única ferramenta.

Onde ela roda

Linha de comando em Linux, Windows e macOS. Também tem uma interface gráfica (Zenmap) para quem está começando.

Por que aprender ela primeiro

É o denominador comum: dominá-la facilita aprender qualquer outra ferramenta de varredura depois.

Nmap: sintaxe e flags mais usadas

Comandos combinam flags – a sintaxe geral é `nmap [flags] [alvo]`.

Flag	Significado
<code>-sS</code>	SYN scan (half-open) – o tipo padrão e mais usado
<code>-sT</code>	Connect scan – completa o handshake, não exige privilégio
<code>-sU</code>	Varredura de portas UDP
<code>-sV</code>	Detecta a versão do serviço rodando em cada porta aberta
<code>-O</code>	Tenta identificar o sistema operacional do alvo
<code>-p</code>	Define quais portas varrer – ex.: <code>-p 1-1000</code> ou <code>-p 80,443</code>
<code>-A</code>	Modo agressivo – combina <code>-sV</code> , <code>-O</code> e scripts básicos
<code>-T4</code>	Define a velocidade do scan (0 = muito lento, 5 = muito rápido)

Combinando flags para cada situação

Na prática, as flags raramente aparecem sozinhas – cada combinação serve um objetivo específico.

`nmap -sS -p- alvo`

Varre todas as 65.535 portas TCP com SYN scan – reconhecimento completo, porém mais lento.

`nmap -sV -sC alvo`

Detecta versões de serviço e roda os scripts padrão do NSE – bom equilíbrio para um primeiro relatório.

`nmap -Pn -p 80,443 alvo`

Ignora a checagem de host ativo (-Pn) – útil quando o alvo bloqueia ping mas as portas respondem.

`nmap -sU -sS -p U:53,T:22,80 alvo`

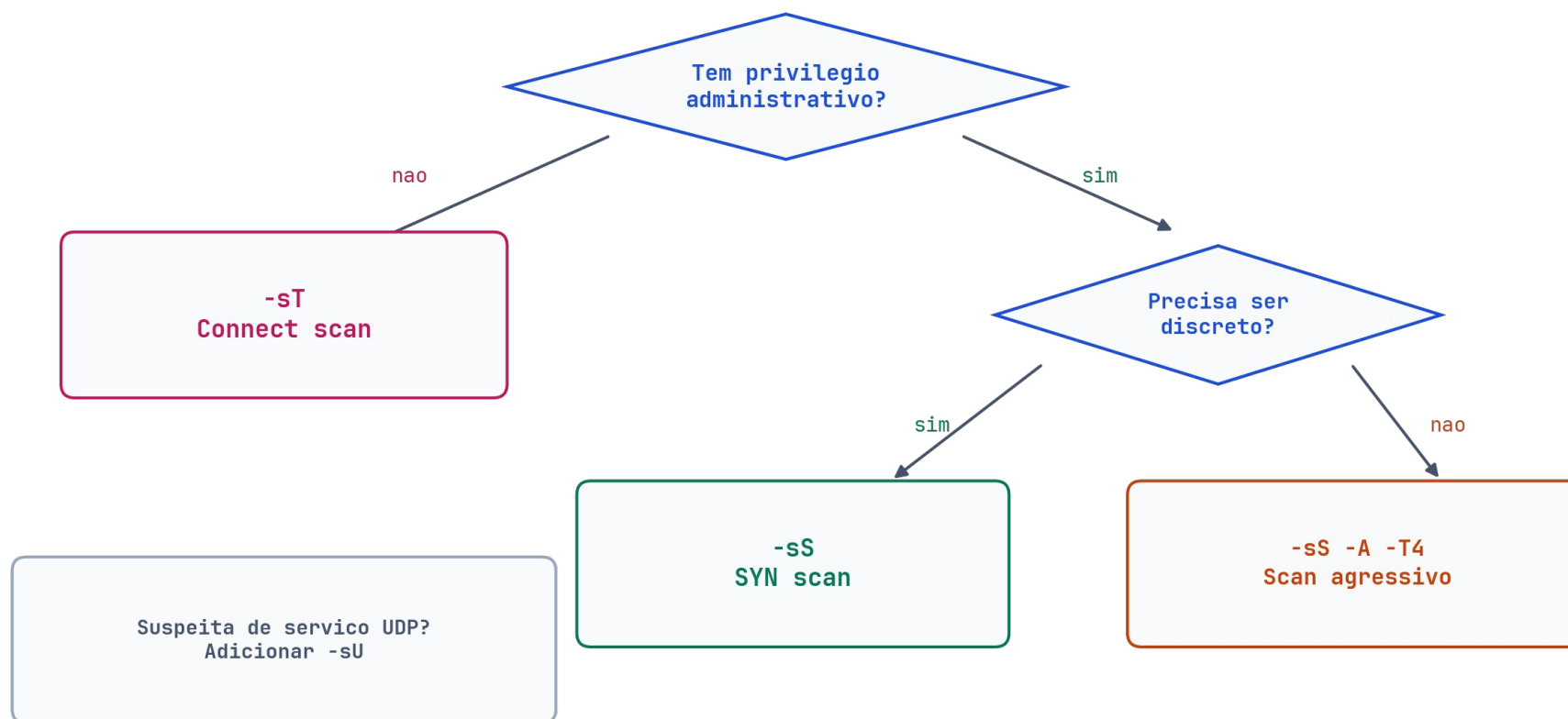
Combina varredura UDP e TCP na mesma execução, especificando portas por protocolo.

`nmap -oN saida.txt alvo`

Salva a saída em um arquivo de texto – essencial para documentar um teste de invasão.

Em diagrama: escolhendo o scan certo

Um fluxo simples para decidir a flag inicial de um scan, a partir do contexto disponível.



Lendo a saída de um scan real

```
nmap -sV -p 1-1000 192.168.1.20
```

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.9p1
80/tcp	open	http	Apache httpd 2.4.52
443/tcp	open	https	Apache httpd 2.4.52
3306/tcp	closed	mysql	
8080/tcp	filtered	http-proxy	

Note: a porta 3306 (MySQL) aparece fechada e a 8080 filtrada – provável firewall bloqueando silenciosamente.

OS fingerprinting: pistas do sistema

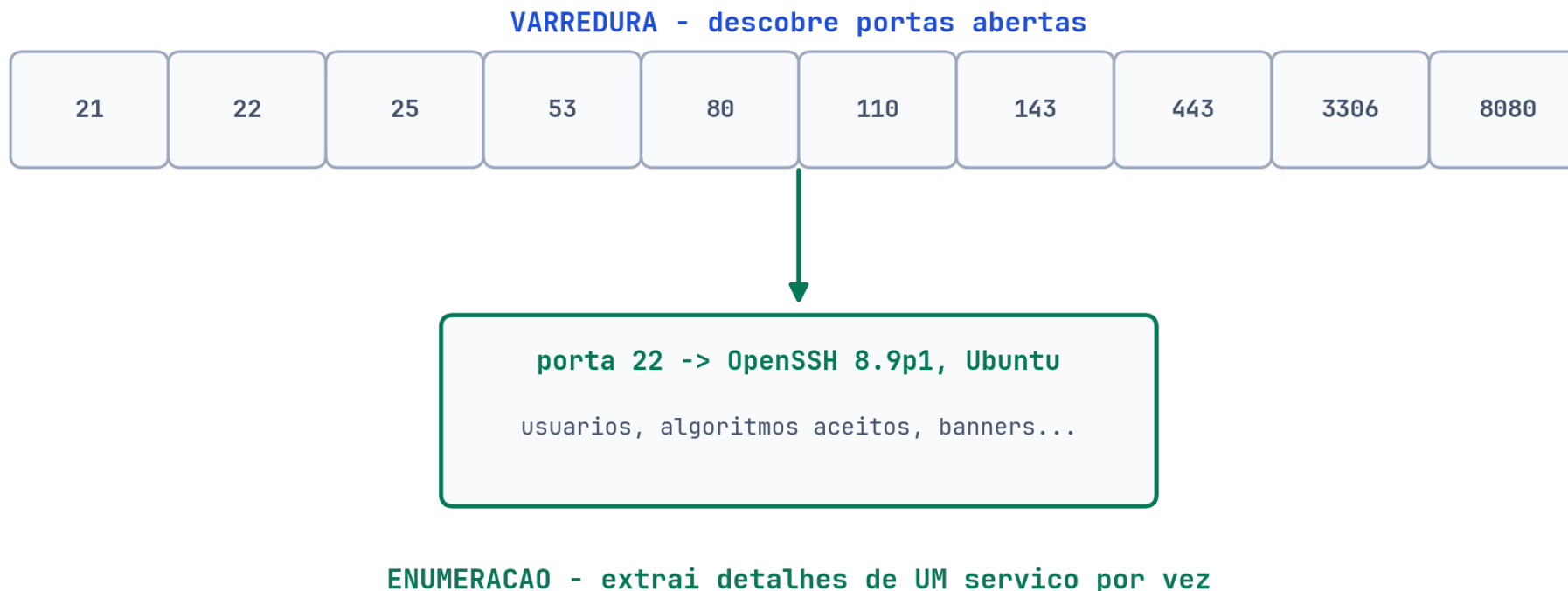
A flag `-O` compara características da pilha TCP/IP do alvo com uma base de assinaturas conhecidas.

Pista	Windows (típico)	Linux (típico)
TTL inicial	128	64
Tamanho de janela TCP	65.535 ou 8.192	5.840 ou 29.200
Ordem das opções TCP	MSS, NOP, WS, NOP, NOP, SACK	MSS, SACK, TS, NOP, WS
Resposta a pacotes malformados	Varia por versão	Segue RFC de forma mais estrita

O TTL é a pista mais rápida de observar: um TTL de 64 chegando como 61 sugere ~3 saltos de roteador até o alvo – já dá uma ideia da distância de rede.

Varredura x enumeração: qual a diferença?

A varredura é ampla e rasa; a enumeração é estreita e profunda.



Banner grabbing

A técnica mais simples de enumeração: perguntar diretamente ao serviço quem ele é.

Muitos serviços se apresentam automaticamente ao aceitar uma conexão – esse texto de apresentação é o “banner”, e frequentemente revela o software e a versão exata em uso.

```
$ nc 192.168.1.20 22
```

```
SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.4
```

```
$ nc 192.168.1.20 21
```

```
220 ProFTPD 1.3.5a Server ready.
```

Banner grabbing

A técnica mais simples de enumeração: perguntar diretamente ao serviço quem ele é.

- Remover versões dos *banners*. Prefira Server: nginx em vez de Server: nginx/1.26.2.
- Remover *headers* desnecessários, especialmente X-Powered-By, X-AspNet-Version e equivalentes.
- Desabilitar *banners* detalhados em SSH, FTP, SMTP etc., quando o serviço permitir.
- Não criar *banners* falsos como principal defesa. Isso é *security through obscurity* e scanners normalmente conseguem fazer *fingerprinting* por outros meios.
- Manter serviços atualizados. Ocultar a versão reduz reconhecimento, mas não corrige vulnerabilidades.
- Fechar portas e serviços desnecessários com *firewall/security groups*.
- Restringir serviços administrativos por VPN, *allowlist* de IP ou rede interna.
- Usar reverse *proxy*/WAF para evitar exposição direta de aplicações e servidores backend.

```
HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Mon, 17 Aug 2026 19:55:21 GMT
Content-Type: text/html
Content-Length: 612
Connection: keep-alive
X-Powered-By: PHP/7.4.3
```

```
SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.5
```

```
*****
* Ubuntu Server 20.04 LTS                               *
* OpenSSH Server - Production                           *
* Host: srv-web-prod-01                                  *
*****
```

```
login:
```

O que cada protocolo costuma revelar

Serviço	Porta	O que a enumeração revela
SMB	445	Nome do domínio, compartilhamentos, versão do Windows, usuários locais
FTP	21	Se aceita login anônimo, versão do servidor, listagem de diretórios
SSH	22	Versão do OpenSSH, algoritmos de criptografia aceitos
HTTP/HTTPS	80/443	Tecnologia do servidor web, CMS, diretórios expostos, certificado TLS
SNMP	161	Configuração de rede, uptime, e às vezes até credenciais (community strings padrão)
DNS	53	Transferência de zona mal configurada pode revelar todos os hosts de um domínio

Indo além: Nmap Scripting Engine (NSE)

O Nmap não para na varredura – ele também roda scripts prontos de enumeração e até detecção de vulnerabilidades.

```
nmap --script vuln -p 80,443 192.168.1.20
```

Roda uma bateria de scripts de detecção de vulnerabilidades conhecidas contra os serviços web encontrados.

`--script default`

Scripts seguros e rápidos, rodados com `-sV -A`

`--script safe`

Não afetam o alvo – apenas coletam informação

`--script vuln`

Procuram vulnerabilidades conhecidas especificamente

Além do Nmap: um panorama rápido

Cada serviço costuma ter uma ferramenta especializada de enumeração – o Nmap é o ponto de partida, não o único destino.

enum4linux	Enumeração completa de compartilhamentos e usuários SMB/Windows
smbclient	Navega e acessa compartilhamentos SMB diretamente, como um cliente
nikto	Varredura de vulnerabilidades específicas em servidores web
gobuster / dirb	Descobre diretórios e arquivos escondidos em um servidor web

Nmap x Masscan x Zenmap: quando usar cada um

Ferramenta	Ponto forte	Limitação
Nmap	Detecção de versão, NSE, fingerprinting – o mais completo	Mais lento em varreduras muito grandes (milhões de IPs)
Masscan	Varre a internet inteira em minutos – extremamente rápido	Não faz detecção de versão/serviço por padrão, menos preciso
Zenmap	Interface gráfica do Nmap – bom para iniciantes e relatórios visuais	Mesmas limitações de velocidade do Nmap, camada extra de UI

Na prática: Masscan para descobrir hosts ativos em escala, Nmap para aprofundar em cada um.

Evasão: fragmentação de pacotes

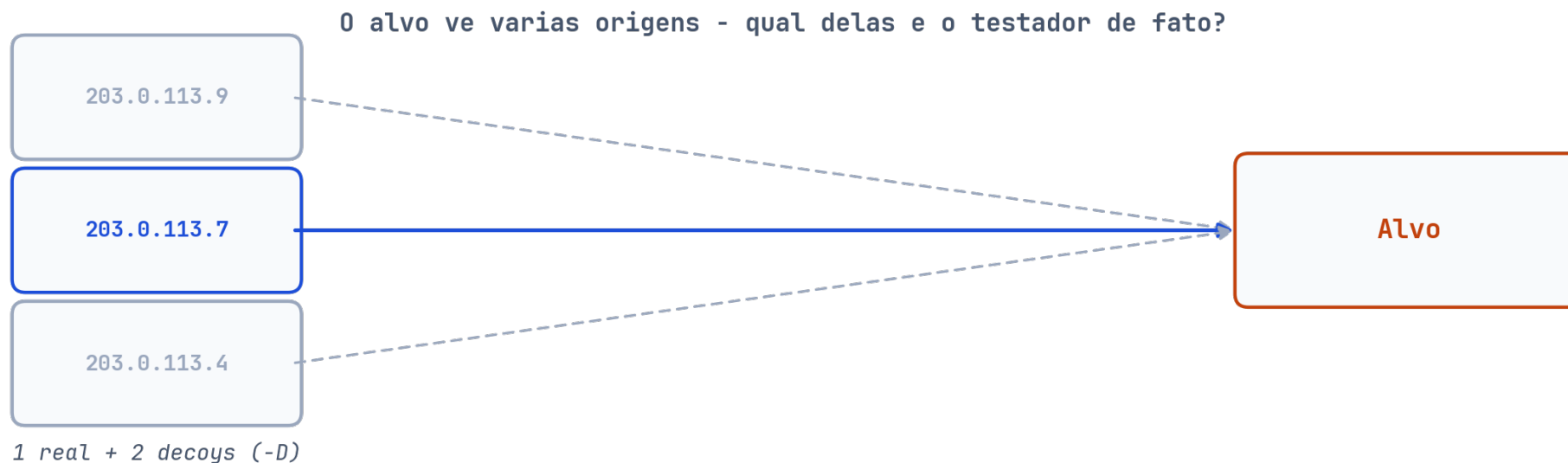
`-f` divide o pacote TCP em fragmentos menores, dificultando a inspeção por firewalls simples.



Firewalls simples inspecionam pacote a pacote - fragmentos pequenos dificultam a análise

Evasão: decoy scan

-D mistura IPs falsos com o real, dificultando saber qual origem é o testador de fato.



Outras técnicas: scan lento (-T0/-T1) para ficar abaixo do limiar de detecção, e spoofing de origem (-S), mais útil em laboratório que em campo.

Varredura não autorizada é crime

A Lei 12.737/2012, já vista na Aula 02, tipifica a invasão de dispositivo alheio – e varrer portas de um sistema sem autorização já pode ser enquadrado como preparação ou tentativa, dependendo do contexto e da intenção.

Escopo por escrito

Todo pentest profissional começa com um contrato definindo exatamente quais IPs e horários estão autorizados.

Ambientes de prática

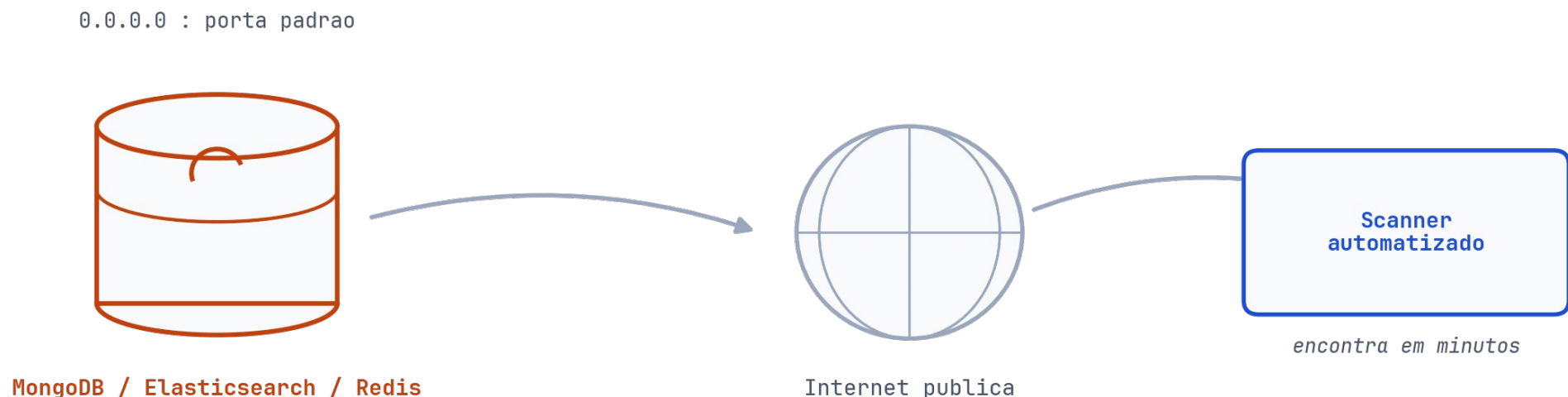
scanme.nmap.org e plataformas como TryHackMe/HackTheBox existem justamente para praticar de forma legal.

Regra de ouro

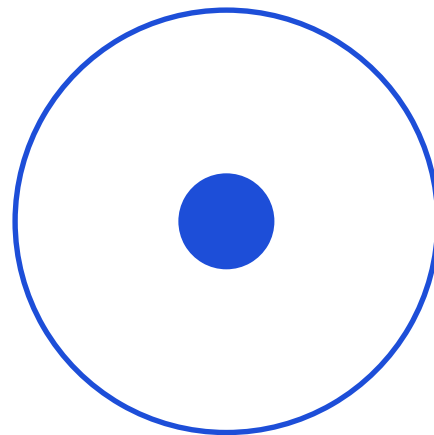
Nunca varra um alvo que você não tem permissão explícita para testar – nem "só para aprender".

Bancos de dados expostos sem autenticação

Um padrão recorrente desde 2017: instâncias sem senha, encontradas por varredura em massa.



Lição para hoje: o mesmo comando `-sV` que rodamos identifica esse tipo de exposição – a defesa começa por varrer a própria rede.



INTERVALO

15 minutos – depois voltamos com Nmap na prática

Primeiro scan: mão na massa

Vamos rodar juntos um scan básico em um alvo público de prática – `scanme.nmap.org`.

- 1 Confirmar o alvo** `scanme.nmap.org` é mantido pelo próprio projeto Nmap especificamente para prática autorizada.
- 2 Rodar o comando** `nmap -sV -T4 scanme.nmap.org` – varredura com detecção de versão, velocidade moderada.
- 3 Ler a saída** Identificar juntos: quais portas apareceram, quais serviços, quais estados.
- 4 Registrar** Cada aluno anota as portas abertas encontradas – usaremos isso na próxima atividade.

Em duplas: interpretando resultados de varredura

Cada dupla recebe uma saída de nmap impressa e resolve os três cenários abaixo.

CENÁRIO A

Dado um resultado com 3 portas abertas (22, 80, 3306), identifiquem os serviços prováveis e um risco de cada um.

CENÁRIO B

Uma porta aparece "filtered" em vez de "closed". Expliquem a diferença prática entre os dois estados.

CENÁRIO C

O alvo está atrás de NAT com apenas a porta 443 exposta. O que isso implica sobre os outros hosts da rede?

10 minutos em duplas – depois cada dupla compartilha uma resposta com a turma.

Pontos-chave da discussão

- 1 Porta 3306 (MySQL) exposta é quase sempre um risco – bancos de dados não deveriam estar acessíveis diretamente da internet.
- 2 "Filtered" significa que existe um firewall no caminho – "closed" significa que o host respondeu, mas não há serviço ali.
- 3 Só a porta 443 exposta atrás de NAT sugere port forwarding único – os demais hosts da rede provavelmente seguem inacessíveis de fora.

Exercícios de fixação

Resolvam individualmente – revisamos as respostas na próxima aula.

- 1 Diferencie varredura de portas e enumeração de serviços em uma frase cada.
- 2 Por que um SYN scan é considerado mais "discreto" que um Connect scan?
- 3 O que significa uma porta aparecer como "filtered" em vez de "closed"?
- 4 Explique como o NAT limita o que uma varredura externa consegue enxergar.
- 5 Cite duas informações que o banner grabbing pode revelar sobre um serviço.

Glossário da aula

Termo	Definição resumida
Port scanning	Técnica de descobrir portas abertas em um host
SYN scan	Scan que interrompe o handshake TCP após o SYN-ACK
Porta filtrada	Um firewall descarta o pacote antes de qualquer resposta
Enumeração	Extração de detalhes de um serviço já identificado como aberto
Banner grabbing	Ler a mensagem de apresentação automática de um serviço
NSE	Nmap Scripting Engine – scripts prontos de enumeração/detecção

Atividade discente efetiva

Para a próxima aula, uma lista com exercícios de varredura e enumeração para fixação do conteúdo, que serão corrigidos no início da próxima aula.

REFERÊNCIA BIBLIOGRÁFICA

TANENBAUM, A. S. Redes de computadores. 4. ed. Rio de Janeiro: Campus, 2003.

HUNT, Craig; RÜDIGER, Deborah. Linux: servidores de rede. Rio de Janeiro: Ciência Moderna, 2004.

0 que vimos hoje

Recapitulando os pilares da Aula 04.

- Fases do teste de invasão: zoom em varredura e enumeração
- Tipos de scan TCP e por que UDP é mais difícil
- Banner grabbing e enumeração por protocolo
- NAT e varredura: o que um testador externo realmente vê
- Estados de porta: aberta, fechada e filtrada
- Nmap: sintaxe, flags e leitura de resultados
- NSE: scripts de enumeração e detecção de vulnerabilidades
- Aspectos legais: varredura exige autorização explícita

Unidade 1 – de portas abertas a vulnerabilidades

- Aprofundar a análise de versões de serviço em busca de vulnerabilidades conhecidas (CVE)
- Introduzir bancos de dados de vulnerabilidades (NVD, Exploit-DB) e como consultá-los
- Relacionar os resultados de enumeração de hoje com a etapa de exploração

Até a próxima aula: guardem a saída de scan que sua dupla anotou hoje – vamos usá-la como ponto de partida para procurar vulnerabilidades reais.

— ENCERRAMENTO

Dúvidas?

Professor José Carlos Neto
j.neto@ufn.edu.br

0	0	1	1	0	1
0	0	0	0	1	1
1	0	1	1	1	1
0	0	1	0	1	1
1	0	0	0	1	1
0	0	0	1	0	1
1	1	1	0	0	1
1	1	1	0	0	1
1	0	0	0	1	0